

INSTITUTO FEDERAL
Mato Grosso do Sul

# Construção de Páginas Web III

Milena Alegre

INSTITUTO FEDERAL
Mato Grosso do Sul

# OWASP TOP10

Vulnerabilidades Críticas de Aplicação e Defesa em Camadas pelo HTTP Server-Side

**Premissa de Arquitetura de Segurança**

### Interresse Transversal

A segurança não deve ser tratada pontualmente nos controllers. Funciona como **Cross-Cutting Concern** interceptado via Middlewares antes da lógica de negócio.

**Dica para Concursos Públicos**

Questões de TI cobram com frequência a classificação das vulnerabilidades OWASP e a ordem exata de execução dos Middlewares no ciclo Request-Response.



INSTITUTO FEDERAL
Mato Grosso do Sul

# OWASP TOP10

## Panorama Global de Riscos Críticos

| Código | Categoria de Risco | Mecanismo Central da Vulnerabilidade |
|---|---|---|
| A01:2021 | **Broken Access Control** | Falha na restrição de ações/dados entre usuários (IDOR, Escalada). |
| A02:2021 | **Cryptographic Failures** | Exposição de dados sensíveis por falta ou fraqueza de cifragem. |
| A03:2021 | **Injection (SQLi, XSS)** | Dados não confiáveis interpretados diretamente como comandos. |
| A05:2021 | **Security Misconfiguration** | Headers inseguros, CORS permissivo e debug ativo em produção. |
| A08:2021 | **Software & Data Integrity** | Inclusão de código sem validação de assinatura e falhas de CSRF. |

**Ponto Crítico:** O Broken Access Control (A01) subiu para a 1ª posição mundial. Mais de **94% das aplicações testadas** apresentam vulnerabilidades de controle de acesso.

INSTITUTO FEDERAL
Mato Grosso do Sul

# OWASP TOP10

## Controle de Acesso: IDOR e Escalada de Privilégios

### ↔ Escalada Horizontal

Acesso a recursos de outros usuários do mesmo nível.

`/api/user/102/fatura → /api/user/103/fatura`

### Escalada Vertical

Usuário comum executa funções exclusivas de Administrador.

`POST /api/admin/delete-user`

### IDOR (Insecure Direct Object References)

Exposição de referências diretas a objetos no banco de dados (ex: chaves primárias sequenciais) sem validar a posse do recurso.

**Solução Arquitetural:** Utilizar UUIDs v4 e filtro direto no repositório SQL: `WHERE id = :id AND tenant_id = :user_id`

INSTITUTO FEDERAL
Mato Grosso do Sul

# OWASP TOP10

## Controle de Acesso: RBAC vs. ABAC

| Característica | RBAC (Role-Based) | ABAC (Attribute-Based) |
|---|---|---|
| **Conceito Central** | Acesso por Papel / Função (Admin, Editor, Aluno). | Acesso por Atributos do Sujeito, Recurso e Ambiente. |
| **Granularidade** | Grosso modo (Coarse-grained). Estático. | Fina (Fine-grained). Dinâmico e contextual. |
| **Regra Exemplo** | `if (user.role === 'ADMIN')` | `if (user.dept === doc.dept && time < 18h)` |
| **Complexidade** | Baixa. Risco de "Explosão de Roles". | Elevada. Requer motor de políticas (XACML). |

**Quando adotar no CPW3?**

Em sistemas convencionais, o RBAC resolve 80% dos casos via middlewares. Adote ABAC para regras contextuais complexas (ex: "Médico acessa prontuário apenas durante o plantão ativo").

INSTITUTO FEDERAL
Mato Grosso do Sul

# OWASP TOP10

## CSRF (Cross-Site Request Forgery) & Proteções

### O Ataque CSRF

Induz o navegador autenticado da vítima a executar ações involuntárias explorando a confiança do servidor nos cookies armazenados.

### Anti-CSRF Tokens `X-CSRF-Token`

Tokens imprevisíveis no cabeçalho exigidos em rotas de mutação (POST/PUT/DELETE).

### SameSite Cookie Attribute

**Strict:** Cookie nunca enviado cross-site.
**Lax:** Cookie enviado apenas em navegações GET de topo.



INSTITUTO FEDERAL
Mato Grosso do Sul

# OWASP TOP10

## Defesas em Camadas: XSS & SQL Injection

### SQL Injection (SQLi)

Injeção de comandos SQL maliciosos via parâmetros HTTP não sanitizados.

**Mitigação Principal**

- Prepared Statements / Parameterized Queries
- Adocão de ORMs seguros (Prisma, TypeORM, Hibernate)

### Cross-Site Scripting (XSS)

Injeção de scripts JavaScript maliciosos executados no navegador da vítima.

**Mitigação Principal** HttpOnly

- Escape de saída HTML contextual
- Cookie com flag (protege cookies)
- Configuração de **Content Security Policy (CSP)**

INSTITUTO FEDERAL
Mato Grosso do Sul

# OWASP TOP10

## Pipeline de Middlewares: Chain of Responsibility




### Curto-Circuito (Short-Circuiting) `res.status(401)`

Se a validação falhar (ex: Token JWT inválido), o middleware interrompe a cadeia retornando sem invocar o .

### Ordem de Declaração Importa

Middlewares globais de parse de body e sanitização de entrada devem obrigatoriamente executar antes das rotas de negócio.

INSTITUTO FEDERAL
Mato Grosso do Sul

# OWASP TOP10

## O que FAZER no Backend

- Validar autorização em todas as rotas.
- Usar Prepared Statements em queries SQL.
- Configurar cookies HttpOnly, Secure e SameSite.
- Tratar erros sem expor stack traces.

## O que NUNCA Fazer

- Confiar em validações feitas apenas no Front-End.
- Passar senhas ou dados sensíveis em URLs (GET).
- Desativar CORS/CSRF para facilitar o desenvolvimento.
- Salvar senhas sem hashing forte (use bcrypt/argon2).

INSTITUTO FEDERAL
Mato Grosso do Sul

# O ciclo da sessao HTTP

**01**

### Autenticação Inicial

Usuário envia credenciais válidas via POST no login.

**02**

### Criação de Sessão

Servidor gera Session ID e armazena dados em memória.

**03**

### Envio do Cookie

Navegador recebe Cookie com ID de sessão assinado.

**04**

### Validação Contínua

Middleware valida o cookie a cada requisição restrita.

INSTITUTO FEDERAL
Mato Grosso do Sul

# O ciclo da decisão da requisição

1

**Requisição HTTP**

Navegador solicita rota restrita.

2

**Filtro (Middleware)**

Inspeciona o Cookie da Sessão.

3A

**Sessão Válida**

Libera acesso à página solicitada.

3B

**Sessão Ausente**

Redireciona para /login (401).

INSTITUTO FEDERAL
Mato Grosso do Sul

# Protecao

### Autenticação Restrita

Validação contínua da sessão ativa em cada página privada.

### Destruição Explícita

Encerramento total no servidor e limpeza do cookie no cliente.

### Redirecionamento

Desvio automático de acessos anônimos diretamente ao login.

INSTITUTO FEDERAL
Mato Grosso do Sul

# Protecao

## Boas Práticas na Gestão de Sessões

### Regeneração do ID

Regerar o Session ID logo após o login para evitar ataques de fixação de sessão.

### Timeout de Inatividade

Expirar sessões inativas após determinado tempo (ex: 15 minutos).



INSTITUTO FEDERAL
Mato Grosso do Sul

# O Risco do Acesso Direto por URL

## Cenário Sem Filtro

Sem middleware de verificação, qualquer visitante pode digitar a URL diretamente:

```
GET http://localhost:3000/admin/painel
```

O servidor processa a requisição sem checar se há usuário autenticado.

## Cenário Com Filtro (Ideal)

O Middleware intercepta a requisição antes de entregar os dados:

```
Sessão inválida → Redirecionar /login (401)
```

Garantia de segurança centralizada em todas as rotas privadas.



INSTITUTO FEDERAL
Mato Grosso do Sul

# Middleware

O middleware é uma camada de software que atua como uma ponte ou um "tradutor" permitindo que diferentes aplicativos, sistemas e bancos de dados se comuniquem entre si de forma eficiente.

**O que ele faz?**
Conecta sistemas: Une tecnologias diferentes que não foram feitas para conversar diretamente.

Funciona como uma "cola": Fica no meio do caminho (entre o sistema operacional e as aplicações) gerenciando dados, mensagens e requisições.

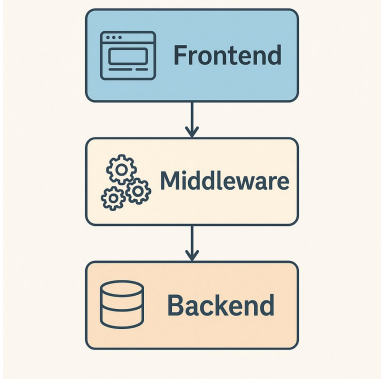
Facilita o trabalho: Evita que programadores precisem criar códigos complexos do zero para integrar sistemas

INSTITUTO FEDERAL
Mato Grosso do Sul

# Middleware

Imagine que você faz uma compra em um site de loja virtual:

1. O site (**frontend**) recebe seu pedido de pagamento.
2. O **middleware** intercepta essa solicitação, verifica se você está logado com segurança e traduz os dados para o sistema do banco.
3. O servidor do banco (**backend**) processa o pagamento e devolve a resposta pelo middleware, que avisa o site se deu tudo certo



INSTITUTO FEDERAL
Mato Grosso do Sul

# Middleware

Função interceptadora executada no pipeline entre a requisição e a resposta final.



### Interceptação

Examina dados de requisição, cookies e cabeçalhos HTTP.



### Tomada de Decisão

Bloqueia o acesso imediatamente ou autoriza o fluxo.



### Encaminhamento

Chama next() para passar o controle à próxima função.

INSTITUTO FEDERAL
Mato Grosso do Sul

# Middleware

**req (Request):** Acessa req.session, parâmetros e cookies.

**res (Response):** Envia respostas HTTP ou faz redirecionamentos.

**next (Function):** Gatilho essencial para liberar a execução da rota.

INSTITUTO FEDERAL
Mato Grosso do Sul

# Http de Interceptacao

| | |
|---|---|
| **1. Cliente envia GET /dashboard** | Header Cookie traz connect.sid |
| **2. express-session recupera req.session** | Busca dados no Session Store |
| **3. Middleware checarAutenticacao executa** | Avalia se req.session.user existe |
| **4. Decisão: next() ou redirect('/login')** | Entrega dashboard ou código 401/403 |

INSTITUTO FEDERAL
Mato Grosso do Sul

# OWASP TOP 10

Open Web Application Security Project: Padrão global de conscientização sobre riscos em softwares web.

### Referência Mundial

Lista atualizada periodicamente com base em dados de ataques globais reais.

### Foco em Desenvolvedores

Fornece diretrizes para escrever código seguro desde a concepção do backend.



INSTITUTO FEDERAL
Mato Grosso do Sul

# OWASP10

## OWASP A01:2021 – Broken Access Control

Falha em impor restrições adequadas sobre o que usuários autenticados ou anônimos podem fazer.

### Bypass de URL

Acessar páginas administrativas sem permissão apenas digitando o link.

### Manipulação de Parâmetros

Alterar IDs na URL para visualizar dados pertencentes a outros usuários.

### Métodos HTTP Elevados

Usar POST/DELETE em APIs sem validação de papéis de acesso no backend.

INSTITUTO FEDERAL
Mato Grosso do Sul

# OWASP10

**CÓDIGO VULNERÁVEL**

```
app.get('/api/relatorio', (req, res) => { // Erro:
Entrega dados sigilosos // sem checar se há usuário
logado! res.json(dadosFinanceiros); });
```

**CÓDIGO CORRIGIDO**

```
app.get('/api/relatorio',  checarAuth, (req, res) => {
// Sucesso: Middleware checarAuth // valida req.session
antes de rodar res.json(dadosFinanceiros); });
```

milena.alegre@ifms.edu.br

INSTITUTO FEDERAL
Mato Grosso do Sul